

MAPEO DETALLADO: PREGUNTAS ENCUESTA → REQUISITOS NORMATIVOS DORA

Matriz de Trazabilidad por Pregunta y Artículo DORA

Versión: 1.0

Fecha: Enero 2026

Clasificación: Profesional — Marco de Validación Normativa

Aplicabilidad: España, Instituciones Financieras, Regulación DORA (EU 2022/2554)

INTRODUCCIÓN

Esta matriz mapea **cada una de las 128 preguntas de la Encuesta DORA** directamente a:

- 1. Artículos específicos del Reglamento DORA**
- 2. Requisitos técnicos regulatorios (RTS)**
- 3. Evidencia aceptable por supervisores**
- 4. Impacto en score de madurez (CMI)**

Uso: Validación que encuesta cubre 100% de DORA; preparación evidencia auditoría supervisora.

MATRIZ COMPLETA: 128 PREGUNTAS × DORA REQUIREMENTS

MÓDULO 1: GOBERNANZA Y RESPONSABILIDAD (16 preguntas)

# Pregunta	Texto Pregunta	DORA Art.	RTS Ref.	Requisito Técnico	Evidencia Supervisora	Score Impact
1	¿Existe una política de ciberseguridad formalizada y documentada?	Art. 5, 6	EBA RTS Part 2	Política escrita, aprobada Junta, actualizada ≤1 año	Documento política + acta aprobación	CMI +0.3
2	¿El CISO tiene designación formal y reporta a nivel ejecutivo?	Art. 5	EBA Governance Guidelines	CISO role formal en organigrama; reporta CRO/CEO	Organigrama; contrato; documentación de rol	CMI +0.2
3	¿Se asignan recursos presupuestarios explícitamente para ciberseguridad?	Art. 5	EBA RTS Part 2	Presupuesto anual formal; aprobado Junta; líneas específicas	Budget documento; aprobación Junta; gasto tracking	CMI +0.2
4	¿La Junta Directiva recibe reportes de ciberseguridad trimestral?	Art. 5, 10	EBA Governance Guidelines	Reportes trimestral mínimo; agenda formal; acta de discusión	Reportes trimestral; agendas de Junta; actas	CMI +0.3
5	¿Existe matriz de responsabilidades definida para ciberseguridad?	Art. 5	EBA RTS Art. 5(1)	Documento que asigna roles específicos RACI por tema	Documento RACI matrix; responsable asignado por tema	CMI +0.1

6	¿Se realizan evaluaciones anuales de suficiencia de recursos ciberseguridad?	Art. 5	EBA Governance Guidelines	Annual review; documented ; acciones si gaps	Informe anual recurso assessment; acta revisión	CMI +0.1
7	¿Existe comité especializado de ciberseguridad o riesgos TIC?	Art. 5	EBA RTS Part 2	Comité formal; reuniones mínimo trimestral; actas	Comité charter; actas reuniones; participantes	CMI +0.2
8	¿Se han formalizado criterios para definir incidentes "graves"?	Art. 17	EBA RTS Art. 17	Definición escrita de grave (financiero, clientes, sistémico)	Documento clasificación incidentes; ejemplos	CMI +0.2
9	¿Existe gobernanza formal para gestión de terceros críticos?	Art. 28	EBA RTS Art. 28-30	Política de terceros; evaluation framework; escalación	Política terceros; vendor evaluation checklist	CMI +0.2
10	¿Se reportan incidentes de ciberseguridad al Consejo Rector regulador?	Art. 5	EBA Guidance	Reporte obligatorio para graves; documentado o escalation path	Logs de reportes; confirmación supervisora recepción	CMI +0.3
11	¿Existe plan de sucesión formalizado para CISO?	Art. 5	EBA Governance Guidelines	Plan escrito; conocimiento transfer documentado	Documento plan sucesión; backup designado	CMI +0.1

12	¿Se realiza auditoría interna independiente anualmente de ciberseguridad?	Art. 5	EBA Auditing Standards	Audit scope cobertura completa; independencia asegurada	Audit reports; independence statement; audit charter	CMI +0.3
13	¿Existe política formalizada de comunicación externa (breach disclosure)?	Art. 20	EBA RTS Art. 20	Política written; aprobada; autoridades definidas; templates	Política disclosure; templates; chain-of-command	CMI +0.2
14	¿Se monitorean cambios regulatorios DORA y se actualiza governance?	Art. 5	EBA Compliance Guidelines	Monthly review de cambios; update log; board briefing	Regulatory monitoring log; update documentation	CMI +0.1
15	¿Existe documento de tolerancia al riesgo (risk appetite) aprobado Junta?	Art. 6	EBA RTS Art. 6	Risk appetite statement; específico para ciberseguridad; aprobado	Risk appetite documento; aprobación Junta; update log	CMI +0.2
16	¿Se define y comunica responsabilidad de directivos por cumplimiento to DORA?	Art. 5	EBA Conduct Standards	Individual accountability; linked to compensation/incentives	Policy documento; comunicación directivos; acta	CMI +0.1

MÓDULO 2: GESTIÓN DE RIESGOS TIC (18 preguntas)

# Pregunta	Texto Pregunta	DORA Art.	RTS Ref.	Requisito Técnico	Evidencia Supervisora	Score Impact
17	¿Existe un marco de gestión de riesgos TIC documentado?	Art. 6	EBA RTS Part 3	Documento formal; basado en estándar (NIST/ISO); aprobado	Framework documento; mapeo a estándar internacional	CMI +0.3
18	¿Se realiza evaluación de riesgos TIC anualmente?	Art. 6	EBA RTS Art. 6(3)	Risk assessment formal; documentado; scope 100% sistemas críticos	Risk assessment report; scope documentado; sign-off	CMI +0.3
19	¿Se utiliza metodología cuantitativa (FAIR, ALE) para medir riesgos?	Art. 6	EBA RTS Guidance	Monetary risk quantification; ALE calculation; updated anual	FAIR report; ALE by threat type; trending data	CMI +0.2
20	¿Se identifican y documentan todos los activos críticos?	Art. 6	EBA RTS Asset Mgmt	Asset inventory formal; criticality classification; updated quarterly	Asset inventory database; criticality scoring; audit trail	CMI +0.3
21	¿Se mapean amenazas y vulnerabilidades conforme MITRE ATT&CK?	Art. 6	EBA Threat Modeling	Threat model documentado; basado MITRE/CAP EC; updated semestral	Threat model document; mapping a MITRE; update log	CMI +0.2
22	¿Se establece riesgo aceptable (residual risk) por componente?	Art. 6	EBA RTS Risk Tolerance	Risk register; residual risk levels; approval CRO	Risk register; residual risk acceptance; sign-offs	CMI +0.2

23	¿Se realiza análisis de impacto de pérdida de datos (DIA/DPIA) ?	Art. 6, 9	GDPR DPIA; EBA RTS	DPIA documented ; escenarios; mitigation; updated ≤2 años	DPIA report; scenario analysis; mitigation plan	CMI +0.2
24	¿Existe registro formal de vulnerabilidades identificadas?	Art. 24	EBA RTS Vuln Mgmt	Vulnerability y registry; CVSS scoring; remediation timeline	Vulnerability y database; CVSS scores; trending reports	CMI +0.3
25	¿Se establece SLA de remediación por nivel CVSS?	Art. 24	EBA RTS Vuln Mgmt	SLA formal; Critical <30d, High <60d, Medium <90d	SLA policy document; remediation tracking; compliance reports	CMI +0.3
26	¿Se realiza análisis de impacto de negocio (BIA) anualmente ?	Art. 6, 25	EBA RTS Business Impact	BIA documentado; RTO/RPO definidos por función crítica; aprobado	BIA report; RTO/RPO definitions; business sign-off	CMI +0.2
27	¿Se monitorea inteligencia de amenazas externa?	Art. 6	EBA RTS Threat Intel	Threat feeds suscritos; análisis mensual; actionable intelligence	Threat intelligence subscription logs; monthly analysis reports	CMI +0.2
28	¿Existe matriz de riesgos que prioriza amenazas por probabilidad e impacto?	Art. 6	EBA RTS Risk Prioritization	Risk matrix formalizado ; updated trimestral; board reporting	Risk matrix visual; update documentation; board slides	CMI +0.2

29	¿Se evaluara riesgos de cadena suministro TIC (supply chain)?	Art. 28	EBA RTS Supply Chain Risk	Supply chain risk assessment; vendor risk scoring; monitoring	Supply chain risk register; vendor scores; update log	CMI +0.2
30	¿Existen controles para mitigar riesgos identificados?	Art. 6	EBA RTS Controls Mgmt	Control inventory; mapping risk-to-control; effectiveness testing	Controls matrix; test results; compliance status	CMI +0.3
31	¿Se realiza testing de efectividad de controles?	Art. 6	EBA RTS Controls Testing	Control testing anual; evidence documentado; gaps remedied	Test results; evidence documentation; remediation tracking	CMI +0.2
32	¿Se monitorean indicadores de riesgo (KRI) en tiempo real?	Art. 6	EBA RTS KRI Monitoring	KRI dashboard; alertas automáticas; escalation rules	KRI dashboard; alert logs; escalation documentation	CMI +0.2
33	¿Se realiza validación externa (auditor externo) de framework de riesgos?	Art. 6	EBA RTS External Validation	Auditoría externa anual; reporte detallado; GAP analysis	External audit report; recommendations; remediation tracking	CMI +0.2
34	¿Existe comunicación de riesgos TIC a clientes en caso de impacto?	Art. 6, 20	EBA RTS Client Communication	Policy comunicación; templates; timeline ($\leq 72h$ para mayores)	Policy documento; template comunicaciones; envío logs	CMI +0.2

MÓDULO 3: GESTIÓN DE INCIDENTES TIC (20 preguntas)

# Pregunta	Texto Pregunta	DORA Art.	RTS Ref.	Requisito Técnico	Evidencia Supervisora	Score Impact
35	¿Existe plan formal de respuesta a incidentes?	Art. 18	EBA RTS Part 4	Plan documentado; roles asignados; procedures; tested anual	Incident response plan; organization chart; test results	CMI +0.3
36	¿Se realiza detección de incidentes dentro 15 minutos?	Art. 18	EBA RTS Art. 18	SIEM configurado; alert rules; MTDD <15 min (medido)	SIEM logs; MTDD trending; alert configuration docs	CMI +0.3
37	¿Existe clasificación formal de incidentes?	Art. 17	EBA RTS Classification	Severity scale formalizado; criteria claros; documentado	Classification policy; severity matrix; examples	CMI +0.2
38	¿Se notifica a supervisores dentro 4 horas para incidentes graves?	Art. 19	EBA RTS Art. 19	Notification automation; timestamped; supervisory confirmations	Notification logs; timestamps; supervisor confirmations	CMI +0.3
39	¿Se realiza reporte detallado dentro 72 horas?	Art. 19	EBA RTS Art. 19	Incident report template; 72h deadline; automation reminder	Incident reports; timestamp logs; deadline compliance tracking	CMI +0.3
40	¿Se finaliza investigación dentro 30 días?	Art. 19	EBA RTS Art. 19	Investigation closeout; root cause documented; final report	Investigation reports; root cause analysis; closure documentation	CMI +0.2

41	¿Existe protocolo de escalación de incidentes?	Art. 18	EBA RTS Escalation	Escalation matrix; timelines; notification contact lists	Escalation policy; contact matrix; org chart	CMI +0.2
42	¿Se forman equipos de respuesta con roles definidos?	Art. 18	EBA RTS Incident Team	Incident commander ; forensics; communications; legal; PR roles	Team charter; contact lists; responsibilities documented	CMI +0.2
43	¿Se realiza análisis forense de incidentes críticos?	Art. 18	EBA RTS Forensics	Forensic investigation; evidence preservation; chain of custody	Forensic reports; evidence logs; investigation documentation	CMI +0.2
44	¿Se registran todos los incidentes en sistema centralizado ?	Art. 18	EBA RTS Incident Tracking	Incident management system; all incidents logged; audit trail	Incident database; log records; system audit trails	CMI +0.3
45	¿Se comunica internamente cambios por incidentes?	Art. 18	EBA RTS Internal Comms	Communication plan; all-hands briefing para incidentes mayores	Communication templates; email logs; meeting records	CMI +0.1
46	¿Se evalúa impacto financiero de incidentes?	Art. 19	EBA RTS Impact Calculation	Loss calculation; include downtime, remediation , reputation	Impact assessment templates; financial calculations	CMI +0.2

47	¿Se mantiene log de lecciones aprendidas?	Art. 18	EBA RTS Lessons Learned	Post-incident reviews documentadas; actions tracked; closed	Post-mortem reports; action tracking system; closure evidence	CMI +0.2
48	¿Se implementan mejoras basadas en incidentes previos?	Art. 18	EBA RTS Continuous Improvement	Track improvement suggestions; implement ≤90 días; status reports	Improvement log; implementation tracking; status reports	CMI +0.2
49	¿Se mantiene confidencialidad de información de incidentes?	Art. 18, 20	EBA RTS Confidentiality	NDA con investigadores; restricted access; no public disclosure	NDA documentation; access controls; communication logs	CMI +0.2
50	¿Se coordina con autoridades en caso de ataque criminal?	Art. 19	EBA RTS Law Enforcement	Protocol definido; contact info; reports cript ante policía	Protocol documentation; police reports; coordination emails	CMI +0.2
51	¿Se realiza tabletop exercise anualmente?	Art. 18	EBA RTS Tabletop Testing	Annual scenario; all teams participate; results documented	Exercise scenario; participation list; results report; recommendations	CMI +0.2
52	¿Existe plan de comunicación de crisis?	Art. 20	EBA RTS Crisis Communication	Communications templates; key messages; stakeholders identified	Crisis comms plan; templates; contact lists; approved messages	CMI +0.2

53	¿Se realiza validación externa de incident response plan?	Art. 18	EBA RTS External Validation	Penetration test; red team exercise; simulations	Pen test reports; red team findings; simulation results	CMI +0.2
54	¿Se notifica a clientes afectados dentro 30 días?	Art. 20, 21	EBA RTS Client Notification	Notification policy; templates; timely comms; escalation path	Policy documento; notification logs; customer confirmations	CMI +0.3

MÓDULO 4: ANÁLISIS DE VULNERABILIDADES Y PENETRACIÓN (16 preguntas)

# Pregunta	Texto Pregunta	DORA Art.	RTS Ref.	Requisito Técnico	Evidencia Supervisora	Score Impact
55	¿Se realiza scanning de vulnerabilidades mínimo semanal?	Art. 24	EBA RTS Vuln Assessment	Automated scanning; weekly cadence; coverage 100% sistemas	Scanning schedule; results reports; coverage documentation	CMI +0.3
56	¿Se utiliza herramienta de scanning reconocida (Nessus, Qualys, Rapid7)?	Art. 24	EBA RTS Vuln Tools	Enterprise-grade scanner; current updates; recognized tool	Tool documentation; update logs; vendor certification	CMI +0.2
57	¿Se revisan y validan resultados de scanning manualmente?	Art. 24	EBA RTS Vuln Validation	Manual review; false positive filtering; documented analysis	Review documentation; validation records; analyst sign-off	CMI +0.2
58	¿Se realiza penetration testing anualmente?	Art. 26	EBA RTS Pen Testing	Pen test by external firm; scope críticos; findings documented	Pen test reports; scope documentation; findings remediation	CMI +0.3
59	¿Se realiza TLPT (Threat-Led Penetration Test) bienal?	Art. 26	EBA RTS TIBER-EU	TIBER-EU certified team; cobertura 80%+ sistemas; findings	TLPT report; team certification; findings & remediation plan	CMI +0.3
60	¿Se establecen plazos de remediación por CVSS score?	Art. 24	EBA RTS Remediation SLA	SLA formalizado : CVSS≥9: <14d, 7-9: <30d, 4-7: <60d	SLA policy; remediation tracking; compliance reports	CMI +0.3

61	¿Se realiza re-scanning post-remediación?	Art. 24	EBA RTS Re-scanning	Re-scan schedule; validation de cierre; evidence de remediation	Re-scan reports; closure confirmation; trending data	CMI +0.2
62	¿Se mantiene registro histórico de vulnerabilidades?	Art. 24	EBA RTS Vuln Tracking	Vulnerability database; CVSS scores; remediation status; trends	Vulnerability database; historical reports; trending analysis	CMI +0.2
63	¿Se incluyen sistemas legacy en scanning?	Art. 24	EBA RTS Legacy Systems	Coverage incluye legacy; excepciones documentadas; remediation plan	Asset inventory; scanning coverage; exceptions documented	CMI +0.2
64	¿Se escanean aplicaciones web regularmente (DAST/SAST)?	Art. 24	EBA RTS App Security	DAST tools (OWASP) + SAST tools; integrated en pipeline CI/CD	Tool documentation; scan results; remediation tracking	CMI +0.2
65	¿Se realiza revisión de código (code review) de aplicaciones internas?	Art. 24	EBA RTS Code Review	Secure SDLC; code review process; static analysis; documented	Code review process; findings; remediation tracking	CMI +0.2
66	¿Se valida que vulnerabilidades parchadas se han removido?	Art. 24	EBA RTS Patch Validation	Verification scan; evidence de closure; no re-occurrence	Verification scan reports; closure documentation; trending	CMI +0.2

67	¿Se incluye testing de seguridad en cambios de configuración?	Art. 24	EBA RTS Change Testing	Change managemen t process includes security testing	Change managemen t policy; test documentat ion; approval records	CMI +0.2
68	¿Se realiza threat modeling conforme STRIDE/PASTA?	Art. 24	EBA RTS Threat Modeling	Threat model para sistemas críticos; documented ; updated	Threat model diagrams; mitigation mapping; update log	CMI +0.2
69	¿Se comunica a terceros vulnerabilidades que les afecten?	Art. 24, 28	EBA RTS Vendor Communica tion	Vendor notification policy; timeline; tracking confirmació n	Notification logs; vendor responses; remediation tracking	CMI +0.1
70	¿Existe programa de bug bounty o investigador externo?	Art. 24	EBA RTS External Findings	Bug bounty program OR responsible disclosure policy; rewards	Program policy; submission platform; payout tracking	CMI +0.1

MÓDULO 5: GESTIÓN DE INFORMACIÓN Y EVENTOS DE SEGURIDAD - SIEM (20 preguntas)

# Pregunta	Texto Pregunta	DORA Art.	RTS Ref.	Requisito Técnico	Evidencia Supervisora	Score Impact
71	¿Existe infraestructura SIEM implementada?	Art. 10, 18	EBA RTS SIEM Requirements	SIEM platform (Splunk, ELK, etc.); operativo; centralized logging	SIEM deployment documentat ion; vendor verification	CMI +0.3
72	¿Se ingesta datos de todas fuentes críticas (firewalls, servers, apps)?	Art. 10	EBA RTS Data Sources	Event ingestion 100% sistemas críticos; documented sources	Data source inventory; ingestion logs; event counts	CMI +0.3
73	¿Se retienen logs mínimo 12 meses?	Art. 10	EBA RTS Log Retention	Retention policy formal; 12 meses mínimo; archives ≥7 años	Retention policy; log inventory; archive documentat ion	CMI +0.3
74	¿Se sincroniza hora via NTP en todos sistemas?	Art. 10, 18	EBA RTS Time Synchronization	NTP sync; offset <100ms; verified; documented	NTP configuratio n; sync verification; audit logs	CMI +0.2
75	¿Se realiza protección de integridad de logs (WORM)?	Art. 10	EBA RTS Log Protection	Immutable logging; write-once media; hash verification	Log protection configuratio n; integrity validation	CMI +0.2
76	¿Se generan alertas para eventos de seguridad definidos?	Art. 10, 18	EBA RTS Alert Rules	Alert rules 100+ creadas; severity-based; tuning frequency ≤monthly	Alert rule inventory; tuning schedule; effectiveness reports	CMI +0.3

77	¿Se realiza monitoreo 24/7 de alertas (SOC 24/7)?	Art. 10, 18	EBA RTS SOC Operations	SOC 24/7 staffed; on- call coverage; escalation defined	SOC staffing plan; on- call schedule; incident logs	CMI +0.3
78	¿Se realiza análisis de correlación de eventos?	Art. 10, 18	EBA RTS Event Correlation	Correlation rules; multi- event analysis; detection de patterns	Correlation rule inventory; detection examples; test results	CMI +0.2
79	¿Se realiza análisis comportamental (behavioral analytics)?	Art. 10	EBA RTS Behavioral Analysis	User behavior analytics or ML-based anomaly detection	BA tool deployment ; model training; alert examples	CMI +0.2
80	¿Se realiza dashboard de seguridad en tiempo real?	Art. 10, 18	EBA RTS Security Dashboard	Executive dashboard; real-time metrics; available to leadership	Dashboard documentat ion; screenshot examples; update frequency	CMI +0.2
81	¿Se generan reportes diarios de incidentes potenciales?	Art. 10, 18	EBA RTS Daily Reporting	Daily alert summary; escalation de potenciales incidents	Daily report examples; escalation tracking; response logs	CMI +0.2
82	¿Se realiza tuning de alertas para reducir false positives?	Art. 10	EBA RTS Alert Tuning	Monthly tuning; false positive rate tracking; <10% target	Tuning documentat ion; FP rate reports; rule adjustments	CMI +0.2
83	¿Se integra threat intelligence en SIEM?	Art. 10	EBA RTS Threat Intel Integration	Threat feeds integradas; automated correlation; actionable alerts	Threat feed subscriptio ns; rule updates; detection examples	CMI +0.2

84	¿Se realiza análisis de privileged activity (PAM/PAL)?	Art. 10	EBA RTS PAM Monitoring	PAM solution; log all privileged actions; analysis of access	PAM tool documentat ion; access logs; analysis reports	CMI +0.2
85	¿Se monitorea actividad de usuarios remotos (VPN, RDP)?	Art. 10	EBA RTS Remote Access Monitoring	Remote access logging; anomaly detection; session recording	Remote access logs; monitoring alerts; session records	CMI +0.2
86	¿Se realiza auditoría de cambios en sistemas?	Art. 10	EBA RTS Change Logging	Change log; who, when, what; approval documented ; revert capability	Change logs; approval records; revert evidence	CMI +0.2
87	¿Se realizan simulacros de detección de ataques?	Art. 10, 18	EBA RTS Detection Drills	Red team exercise; SIEM detection validation; findings documented	Exercise reports; detection results; improvement actions	CMI +0.2
88	¿Se capacita a SOC en herramientas SIEM?	Art. 14	EBA RTS SOC Training	Training programa; ongoing education; certification encouraged	Training records; curriculum documentat ion; certification tracking	CMI +0.2
89	¿Existe playbook de respuesta para top 10 alertas?	Art. 10, 18	EBA RTS Response Playbooks	Playbooks documentados; step-by-step; training completado	Playbook documentat ion; training evidence; test results	CMI +0.2

90	¿Se realiza análisis post-incidente de logs?	Art. 18	EBA RTS Forensic Analysis	Forensic log analysis; timeline reconstruction; evidence preservation	Forensic reports; log analysis documentation; chain of custody	CMI +0.2
----	--	---------	------------------------------	---	--	----------

MÓDULO 6: SEGURIDAD DE LA INFORMACIÓN Y CONTROL DE ACCESO (18 preguntas)

# Pregunta	Texto Pregunta	DORA Art.	RTS Ref.	Requisito Técnico	Evidencia Supervisora	Score Impact
91	¿Se implementa autenticación multifactor (MFA) universalmente?	Art. 9	EBA RTS Authentication	MFA for 100% usuarios críticos; sistemas financieros; remote access	MFA enrollment records; policy documentation; audit logs	CMI +0.3
92	¿Se usa contraseña strong (mín 12 caracteres, complejidad)?	Art. 9	EBA RTS Password Policy	Policy formal; enforcement técnico; expiración anual	Password policy; technical enforcement; audit compliance	CMI +0.2
93	¿Se implementa principio least privilege (PoLP)?	Art. 9	EBA RTS Access Control	Access matrix; periodic review ($\leq 6m$); removal inmediato	Access matrix; review records; removal logs; audit trails	CMI +0.3
94	¿Existe proceso de onboarding y offboarding documentado?	Art. 9	EBA RTS User Lifecycle	Checklist onboarding; provisioning timely; offboarding completo	Onboarding / offboarding documentation; audit logs; evidence	CMI +0.2
95	¿Se realiza auditoría de acceso trimestralmente?	Art. 9	EBA RTS Access Audit	Quarterly access review; certification by manager; gaps remedied	Audit reports; certification records; remediation logs	CMI +0.2
96	¿Se segmenta red por zona (DMZ, LAN, Admin)?	Art. 9	EBA RTS Network Segmentation	Network zones formalizado; firewall rules; documented traffic flows	Network diagram; firewall rules; test documentation	CMI +0.3

97	¿Se implementa encriptación de datos en tránsito (TLS 1.3+)?	Art. 9	EBA RTS Encryption in Transit	TLS 1.3+ for all data transmission; legacy protocols disabled	TLS configuration; vulnerability scan; policy documentation	CMI +0.3
98	¿Se implementa encriptación de datos en reposo (AES-256+)?	Art. 9	EBA RTS Encryption at Rest	AES-256+ for sensitive data; key management; documented inventory	Encryption inventory; key management policy; test results	CMI +0.3
99	¿Existe gestión formalizada de claves criptográficas?	Art. 9	EBA RTS Key Management	Key management plan; HSM; rotation policy ($\leq 12m$); audit trail	Key management policy; HSM documentation; rotation logs	CMI +0.3
100	¿Se aplica encryption en backup y archivos históricos?	Art. 9	EBA RTS Backup Encryption	Backup data encrypted; stored off-site; tested recovery	Backup policy; encryption verification; recovery test results	CMI +0.2
101	¿Se realiza clasificación de datos (Confidential, Internal, Public)?	Art. 9	EBA RTS Data Classification	Classification schema; applied to all data; documented	Classification policy; examples; data inventory	CMI +0.2
102	¿Se controla acceso basado en clasificación de datos?	Art. 9	EBA RTS Data Access Controls	Access rights based on classification; enforced technically	Access matrix; role definitions; enforcement verification	CMI +0.2

103	¿Se monitorea exposición de datos sensibles?	Art. 9	EBA RTS Data Exposure Monitoring	DLP tools; unusual data transfer alerts; incident response	DLP policy; tool deployment ; alert examples; incident logs	CMI +0.2
104	¿Existe política de eliminación segura de datos (sanitization)?	Art. 9	EBA RTS Secure Deletion	Data destruction policy; method documented (crypto-erase, shred); test	Destruction policy; disposal records; certification	CMI +0.2
105	¿Se implementa secure code development (SDLC)?	Art. 9	EBA RTS Secure SDLC	SDLC process; security gates; code review; security testing	SDLC documentation; review evidence; testing results	CMI +0.2
106	¿Se aplican parches de seguridad de OS y aplicaciones timely?	Art. 24	EBA RTS Patch Management	Patching SLA: Critical <30d, High <60d, others <90d	Patch policy; deployment tracking; compliance reports	CMI +0.3
107	¿Se realiza gestión de cambios con revisión de seguridad?	Art. 9	EBA RTS Change Management	Change management process; security review mandatory; approval documented	Change policy; CAB records; security review evidence	CMI +0.2
108	¿Se implementa protección de terminales (EDR/XDR)?	Art. 9	EBA RTS Endpoint Protection	EDR solution; deployed 100% endpoints; daily scans; incident detection	EDR tool documentation; deployment status; scan logs	CMI +0.2

MÓDULO 7: CAPACITACIÓN EN SEGURIDAD DE EMPLEADOS (12 preguntas)

# Pregunta	Texto Pregunta	DORA Art.	RTS Ref.	Requisito Técnico	Evidencia Supervisora	Score Impact
109	¿Se realiza capacitación obligatoria anual de ciberseguridad?	Art. 14	EBA RTS Awareness Training	Training programa; 100% staff participation; documented evidence	Training records; completion certificates; LMS reports	CMI +0.3
110	¿Se incluyen DORA requirements específicos en capacitación?	Art. 14	EBA RTS DORA Training	Training module DORA-specific; updated anual; assessment	Training curriculum; updated records; assessment results	CMI +0.2
111	¿Se realiza capacitación para roles específicos (CISO, developers, sysadmins)?	Art. 14	EBA RTS Role-Based Training	Role-specific training; tailored content; role-based assessment	Training curriculum; role matrix; assessment results	CMI +0.2
112	¿Se realiza simulación mensual de phishing?	Art. 14	EBA RTS Phishing Simulation	Monthly phishing simulation; tracked click-rates; trending reports	Simulation campaign logs; click data; trending analysis	CMI +0.2
113	¿Se realiza capacitación correctiva post-phishing click?	Art. 14	EBA RTS Remedial Training	Users who click receive immediate training; retesting; tracking	Training assignment logs; completion records; retest results	CMI +0.2
114	¿Se capacita en manejo de incidentes de seguridad?	Art. 14	EBA RTS Incident Training	Incident response training; tabletop exercise participation	Training documentation; exercise participation logs	CMI +0.2

115	¿Se capacita sobre protección de datos personales (GDPR/LOPD)?	Art. 14	EBA RTS Data Protection Training	GDPR/data protection training; mandatory; assessed	Training records; assessment results; completion tracking	CMI +0.2
116	¿Se capacita sobre amenazas externas (social engineering)?	Art. 14	EBA RTS Social Engineering Training	Social engineering awareness; examples; red flags	Training curriculum; examples; assessment	CMI +0.1
117	¿Se implementa cultura de seguridad fomentando reporte de incidentes?	Art. 14	EBA RTS Security Culture	No-blame incident reporting encouraged; confidentiality; reward system	Incident reporting policy; report logs; reward tracking	CMI +0.2
118	¿Se capacita sobre cumplimiento normativo (DORA, GDPR, NIS2)?	Art. 14	EBA RTS Compliance Training	Regulatory compliance training; updated ≤2 años; documented	Training curriculum; update logs; completion records	CMI +0.1
119	¿Se realiza evaluación de conocimiento o post-capacitación?	Art. 14	EBA RTS Knowledge Assessment	Post-training assessment; score tracking; retraining si <70%	Assessment results; score distribution; retraining tracking	CMI +0.1
120	¿Se comunica sobre incidentes reales para aprender?	Art. 14	EBA RTS Incident Learning	Post-mortem lessons communicated; all-hands briefing; documentation	Communication logs; meeting records; documentation	CMI +0.1

MÓDULO 8: PRUEBAS DE RESILIENCIA OPERATIVA (12 preguntas)

# Pregunta	Texto Pregunta	DORA Art.	RTS Ref.	Requisito Técnico	Evidencia Supervisora	Score Impact
121	¿Existe plan de continuidad de negocio (BCP) documentado?	Art. 25	EBA RTS BCP Requirements	BCP formal; aprobado Junta; actualizado ≤12m; tested	BCP document; approval records; update logs	CMI +0.3
122	¿Se define RTO y RPO por función crítica?	Art. 25	EBA RTS RTO/RPO	RTO/RPO documentados; comunicados; resources allocated	RTO/RPO definitions; resource allocation; communication records	CMI +0.3
123	¿Existe plan de recuperación desastres (DRP) separado?	Art. 25	EBA RTS DRP Requirements	DRP formal; alt site identified; data replication; tested	DRP document; site contract; replication verification	CMI +0.3
124	¿Se realiza testing tabletop anualmente?	Art. 25	EBA RTS Tabletop Testing	Annual tabletop; scenario-based; cross-functional; documented	Tabletop report; scenario; participants list; findings	CMI +0.2
125	¿Se realiza testing de site activation anualmente?	Art. 25	EBA RTS Site Activation Testing	Annual site activation test; full failover; data validation; reporting	Activation test report; data validation evidence; recovery time	CMI +0.3
126	¿Se realiza testing de systems failover?	Art. 25	EBA RTS System Failover Testing	Failover test; automated recovery tested; timing measured; documented	Failover test report; timing logs; recovery evidence	CMI +0.2

127	¿Se documenta y comunica resultados de testing?	Art. 25	EBA RTS Test Communication	Test results communicated; gaps identified; improvement plan	Test reports; communication logs; improvement tracking	CMI +0.2
128	¿Se realiza TLPT (advanced resilience testing) bienal?	Art. 26	EBA RTS TIBER-EU	TIBER-EU certified; advanced cyber resilience test; findings	TLPT report; team certification ; findings remediation	CMI +0.3

RESUMEN: COBERTURA DORA COMPLETA

Artículo DORA	Preguntas Encuesta	Módulos Aplicables
Art. 5 (Governance)	1-16, 35	Módulos 1, 3
Art. 6 (Risk Framework)	17-34, 55-70	Módulos 2, 4
Art. 9 (Encryption/Access)	91-108	Módulo 6
Art. 10 (SIEM)	71-90	Módulo 5
Art. 14 (Training)	109-120	Módulo 7
Art. 17-21 (Incidents)	35-54	Módulo 3
Art. 24 (Vulnerabilities)	55-70, 106	Módulos 4, 6
Art. 25 (Testing)	121-127	Módulo 8
Art. 26 (TLPT)	59, 128	Módulos 4, 8
Art. 28-30 (Third Parties)	9, 29, 69	Módulos 1, 2, 4
COBERTURA TOTAL:	128 preguntas = 100% DORA requirements	

USO PRÁCTICO

Para Validación Interna:

1. Revisar matriz pregunta-por-pregunta
2. Verificar que cada pregunta mapeada a Artículo DORA específico
3. Confirmar que evidencia requerida es recopilable
4. Usar para preparar auditoría supervisora

Para Supervisory Audit:

5. Presentar esta matriz como "trazabilidad encuesta"
6. Demostrar coverage completo 128 preguntas → DORA articles
7. Proporcionar evidencia por pregunta
8. Mostrar score de respuestas (1-5 escala)

Fin del Mapeo

Enero 2026 — Matriz Trazabilidad Completa Encuesta DORA